

CEN/CLC/JTC 13

Date: 2026-05-12

prEN 40000-1-1

Secretariat: DIN

WI Number: JT013095

Cybersecurity requirements for products with digital elements - Vocabulary

ICS: 01.040.35

CCMC will prepare and attach the official title page.

Contents.....	Page
European foreword.....	Error! Bookmark not defined.
Introduction	Error! Bookmark not defined.
Scope.....	Error! Bookmark not defined.
Normative references.....	Error! Bookmark not defined.
Terms and definitions.....	Error! Bookmark not defined.
Bibliography	Error! Bookmark not defined.

European foreword

This document (prEN 40000-1-1:2025) has been prepared by Technical Committee CEN/CLC/JTC 13 "Cybersecurity and Data Protection", the secretariat of which is held by DIN.

This document is currently submitted to the CEN Enquiry.

This document has been prepared as a supporting document for documents developed under a standardization request C(2025) 618 addressed to CEN by the European Commission.

Introduction

The effective implementation of cybersecurity requirements for products with digital elements relies on a clear and unified understanding of key concepts. This document provides the common language necessary to ensure alignment and consistency across the EN 40000-1 family of European standards.

1 Scope

This document provides the terms and definitions commonly used in the cybersecurity requirements for products with digital elements family of standards.

2 Normative references

There are no normative references in this document.

3 Terms and definitions

For the purposes of this document, the terms and definitions given in the relevant Regulation (EU) 2024/2847 and the following apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <http://www.iso.org/obp>
- IEC Electropedia: available at <http://www.electropedia.org/>

3.1

activity

set of cohesive tasks

[SOURCE: [Error! Reference source not found.](#), 3.1.3, modified – "of a process" has been removed]

3.2

advisory

document or message that provides *vulnerability* (3.38) information intended to reduce risk

Note 1 to entry: An advisory is meant to inform users or other stakeholders about a vulnerability including, if possible, how to identify and remediate vulnerable systems.

[SOURCE: [Error! Reference source not found.](#), 3.8]

3.3

asset

anything that has value to an individual, an organization or a government

[SOURCE: [Error! Reference source not found.](#), 3.1]

3.4

authentication

provision of assurance that an entity is who or what it claims to be

[SOURCE: [Error! Reference source not found.](#), 3.2, modified – note removed]

3.5

authenticity

property that an entity is what it claims to be

[SOURCE: [Error! Reference source not found.](#), 3.1.5]

3.6

availability

property of being accessible and usable on demand by an authorized entity

[SOURCE: [Error! Reference source not found.](#), 3.7]

3.7

component

"software or hardware intended for integration into an electronic information system"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(6)]

3.8

confidentiality

property that information is not made available or disclosed to unauthorized individuals, entities, or processes

[SOURCE: [Error! Reference source not found.](#), 3.10]

3.9

control

measure that maintains and/or modifies risk

Note 1 to entry: Controls include, but are not limited to, any process, policy, device, practice, or other conditions and/or actions which maintain and/or modify risk.

Note 2 to entry: Controls may not always exert the intended or assumed modifying effect.

[SOURCE: [Error! Reference source not found.](#), 3.8]

3.10

coordination

set of activities including identifying and engaging stakeholders, mediating, communicating, and other planning in support of *vulnerability* ([3.38](#)) disclosure

Note 1 to entry: The term "coordinated vulnerability disclosure" is used to denote a disclosure process that includes coordination.

[SOURCE: [Error! Reference source not found.](#), 3.3]

3.11

coordinator

individual or organization that performs *coordination* ([3.10](#))

[SOURCE: [Error! Reference source not found.](#), 3.6]

3.12

cybersecurity

"activities necessary to protect network and information systems, the users of such systems, and other persons affected by cyber threats"

[SOURCE: Definition quoted from Regulation (EU) 2019/881 of the European Parliament and of the Council (Cybersecurity Act), 2.(1)]

3.13

cybersecurity objective

result to be achieved concerning the protection from *cyber threat* ([3.15](#))

3.14

cybersecurity risk

"potential for loss or disruption caused by an incident and is to be expressed as a combination of the magnitude of such loss or disruption and the likelihood of occurrence of the incident"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(37)]

3.15

cyber threat

"any potential circumstance, event or action that could damage, disrupt or otherwise adversely impact network and information systems, the users of such systems and other persons"

[SOURCE: Definition quoted from Regulation (EU) 2019/881 of the European Parliament and of the Council (Cybersecurity Act), 2.(8)]

3.16

electronic information system

"system, including electrical or electronic equipment, capable of processing, storing or transmitting digital data"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(7)]

3.17

embargo period

designated timeframe where the public disclosure of a *vulnerability* ([3.38](#)) is intentionally withheld

Note 1 to entry: The embargo period allows for the development, testing, and integration of remediations. Especially in Multiparty Coordinated Vulnerability Disclosure (MPCVD) environments, it serves to balance the urgency of disclosure against the complexity of ensuring a complete and effective mitigation across a diverse ecosystem of dependent stakeholders.

3.18

hardware

"physical electronic information system, or parts thereof capable of processing, storing or transmitting digital data"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(5)]

3.19

impact

degree of damage or loss that occurs when a *vulnerability* ([3.38](#)) is exploited

3.20

incident

"event compromising the availability, authenticity, integrity or confidentiality of stored, transmitted or processed data or of the services offered by, or accessible via, network and information systems"

[SOURCE: Definition quoted from Directive (EU) 2022/2555 of the European Parliament and of the Council (NIS2), 6.(6)]

3.21

integrity

property of accuracy and completeness

[SOURCE: [Error! Reference source not found.](#), 3.36]

3.22

intended purpose

"use for which a product with digital elements is intended by the manufacturer, including the specific context and conditions of use, as specified in the information supplied by the manufacturer in the instructions for use, promotional or sales materials and statements, as well as in the technical documentation"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(23)]

3.23

likelihood

chance of something happening

[SOURCE: [Error! Reference source not found.](#), 3.40]

3.24

manufacturer

"natural or legal person who develops or manufactures products with digital elements or has products with digital elements designed, developed or manufactured, and markets them under its name or trademark, whether for payment, monetisation or free of charge"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(13)]

3.25

online hosting platform

infrastructure that stores and serves the resources for a website, application, or online service

3.26

product with digital elements

"software or hardware product and its remote data processing solutions, including software or hardware components being placed on the market separately"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(1)]

3.27

reasonably foreseeable misuse

"use of a product with digital elements in a way that is not in accordance with its intended purpose, but which may result from reasonably foreseeable human behaviour or interaction with other systems"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(25)]

3.28

reasonably foreseeable use

"use that is not necessarily the intended purpose supplied by the manufacturer in the instructions for use, promotional or sales materials and statements, as well as in the technical documentation, but which is likely to result from reasonably foreseeable human behaviour or technical operations or interactions"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(24)]

3.29

remediation

change made to a product, document or service to remove or mitigate a *vulnerability* (3.38)

Note 1 to entry: A remediation typically takes the form of a binary file replacement, configuration change, or source code patch and recompile. Different terms used for "remediation" include patch, fix, update, hotfix, and upgrade. Mitigations are also called workarounds or countermeasures.

[SOURCE: [Error! Reference source not found.](#), 3.7, modified – "document" added to definition]

3.30

remote data processing

"data processing at a distance for which the software is designed and developed by the manufacturer, or under the responsibility of the manufacturer, and the absence of which would prevent the product with digital elements from performing one of its functions"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(2)]

3.31

reporter

individual or organization that notifies a *manufacturer* (3.24) or coordinator of a potential vulnerability

Note 1 to entry: There are no special preconditions for acting as a reporter. Reporters can be individuals, organizations, amateurs or hobbyists, professionals, end-users, security research organizations, manufacturers, governments, or coordinators

[SOURCE: [Error! Reference source not found.](#), 3.5, modified – "vendor" replaced by "manufacturer", "requirement" replaced by "precondition"]

3.32

residual risk

cybersecurity risk (3.14) remaining after risk treatment

[SOURCE: [Error! Reference source not found.](#), 3.1.57, modified – "cybersecurity" added to align with CRA terminology; notes removed]

3.33

review

activity undertaken to determine the suitability, adequacy and effectiveness of the subject matter to achieve established objectives

[SOURCE: [Error! Reference source not found.](#), 3.3.41]

3.34

software

"part of an electronic information system which consists of computer code"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(4)]

3.35

software bill of materials

"formal record containing details and supply chain relationships of components included in the software elements of a product with digital elements"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(39)]

3.36

software package

bundled collection of *software* ([3.34](#)), data, or a combination of both

3.37

test

activity in which a system or component is executed under specified conditions, the results are observed or recorded, and an evaluation is made of some aspect of the system or component

Note 1 to entry: A test is carried out to measure or classify a characteristic or a property of an item by applying to the item a set of environmental and operating conditions and/or requirements.

[SOURCE: [Error! Reference source not found.](#), 3.21]

3.38

vulnerability

"weakness, susceptibility or flaw of a product with digital elements that can be exploited by a cyber threat"

[SOURCE: Definition quoted from Regulation (EU) 2024/2847 of the European Parliament and of the Council (Cyber Resilience Act), 3.(40)]

Bibliography

- [1] ISO/IEC/IEEE 12207:2017, *Systems and software engineering — Software life cycle processes*
- [2] ISO/IEC 29147:2018, *Information technology — Security techniques — Vulnerability disclosure*
- [3] ISO/IEC 27035-3:2020, *Information technology — Information security incident management — Part 3: Guidelines for ICT incident response operations*
- [4] EN 18031-1:2024, *Common security requirements for radio equipment - Part 1: Internet connected radio equipment*
- [5] ISO/IEC 27002:2022, *Information security, cybersecurity and privacy protection — Information security controls*
- [6] ISO/IEC 27000:2018, *Information technology — Security techniques — Information security management systems — Overview and vocabulary*
- [7] ISO 31000:2018, *Risk management — Guidelines*
- [8] ISO/IEC 27005:2022, *Information security, cybersecurity and privacy protection — Guidance on managing information security risks*
- [9] ISO 31073:2022, *Risk management — Vocabulary*
- [10] ISO/IEC/IEEE 29119-2:2021, *Software and systems engineering — Software testing — Part 2: Test processes*